

AI-Driven Internal Infrastructure Architectures

プロジェクト概要

本プロジェクトは、ホテル予約システム（Type-B / Type-Omega）と同じ設計哲学を社内インフラに適用した比較検証プロジェクトです。

「どんな企業文化を持つ組織のために、誰が働くかによって、社内インフラの思想は根本から変わるべきである」

外部顧客向けシステムでは「どんなホスピタリティを提供するか」がアーキテクチャを決めました。社内インフラでは「どんな企業文化・働き方を支えるか」がアーキテクチャを決めます。

2つのアーキテクチャモデル

Type-B: Enterprise Edition（伝統・統制型）

「変えないことが信頼の証明。既存資産を守りながら、見えないところだけ進化する。」

想定モデル: 大手日系製造業・金融・官公庁。20年以上稼働するオンプレミスサーバーとActive Directoryを持ち、急激な変化がコンプライアンス違反やシステム障害に直結する環境。

設計思想:

- 既存のActive DirectoryとオンプレミスをAWSとハイブリッド接続する
- 社員は今まで通りの操作感でシステムを使う（変化を感じさせない）
- セキュリティと監視レイヤーだけをAIで強化する
- コンプライアンス（CIS Benchmark・NIST）への自動準拠を徹底する

セキュリティの思想: 発見的統制。怪しい挙動を検知して対応する。変更管理プロセスをインフラで強制する。

Type-Omega: Cloud-Native Edition（先端・自律型）

「VPNをなくす。場所を問わない。IDだけを信頼する。」

想定モデル: SaaS系スタートアップ・デジタルネイティブ企業・フルリモート組織。オンプレなし、Active Directoryなし、全員がMacBookとSlackで働く環境。

設計思想:

- VPNを廃止し、IDとデバイス証明書だけでアクセスを制御する（ZTNA）
- 開発者がGuardrails（上限・制約）の範囲内で自律的にリソースをプロビジョニングできる
- セキュリティをコードとして実装し、人手の運用を最小化する
- GitHub Actions + Terraformで全インフラをコードで管理する

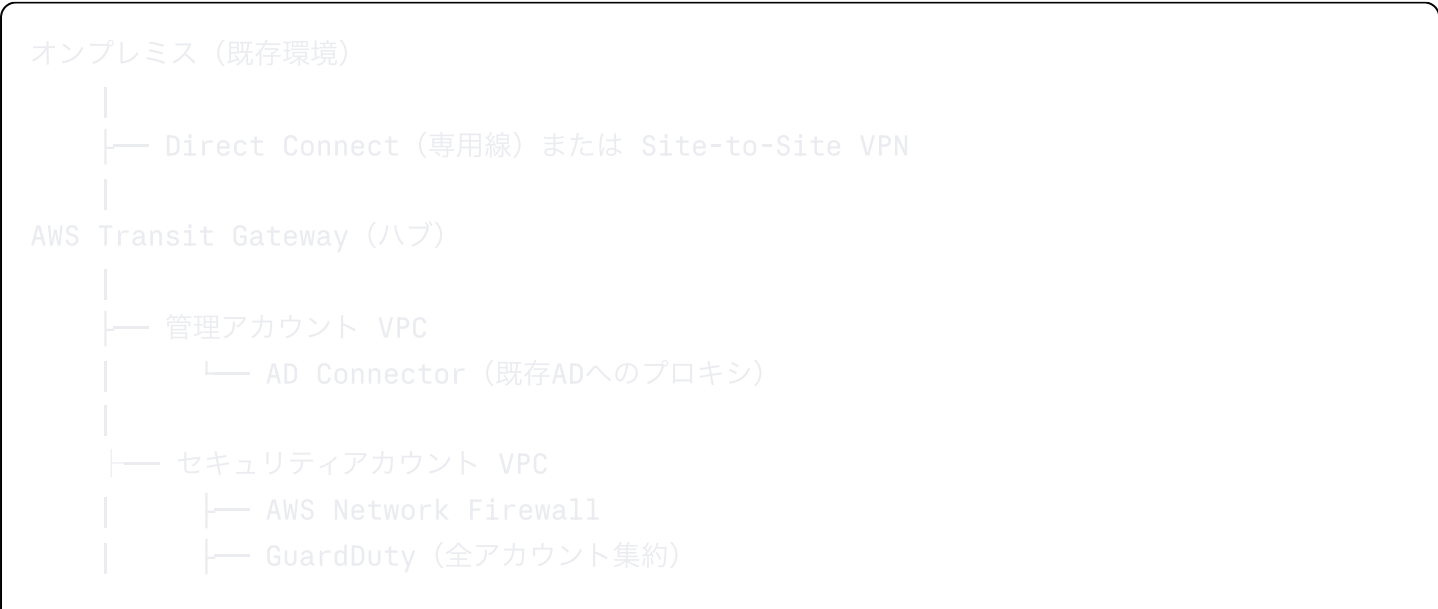
セキュリティの思想: 予防的統制。そもそも侵入させない設計。信頼はネットワーク位置ではなくIDで決まる。

アーキテクチャ比較表

項目	Type-B（伝統・統制型）	Type-Omega（先端・自律型）
想定組織	大手日系企業・金融・官公庁	SaaS系スタートアップ・フルリモート
既存資産	Active Directory・オンプレサーバーあり	クラウドネイティブ・レガシーなし
ネットワーク	ハイブリッド（Direct Connect + VPN）	VPNなし・AWS Verified Access（ZTNA）
ID管理	AD Connector（既存ADと連携）	IAM Identity Center + SCIM（Okta/Google Workspace）
開発者体験	承認プロセス必須・変更管理あり	セルフサービス・Guardrails内で自由
セキュリティ	検知・対応型（SIEM的アプローチ）	予防・自動化型（Policy as Code）
コンプライアンス	CIS Benchmark・NIST自動監査	AWS SCPによるポリシー強制
AIの役割	脅威の自律検知・対応（OpenClaw Enterprise）	セルフサービスポータルでのAIアシスト

Type-B: Enterprise Edition 詳細設計

ネットワーク構成





主要コンポーネント

Identity層

- `aws_directory_service_directory` — AD Connector (既存Active Directoryへのプロキシ)
- `aws_iam_identity_center` — AWS IAM Identity Center (既存ADユーザーをAWSに連携)
- MFA強制 (TOTP / FIDO2)

Network層

- `aws_ec2_transit_gateway` — 全VPCのハブ。アカウント間通信を制御
- `aws_networkfirewall_firewall` — 東西・南北トラフィックを検査
- `aws_vpn_connection` — オンプレミスとの接続 (Direct Connect推奨)
- `aws_flow_log` — 全VPCのトラフィックログをS3/CloudWatch Logsへ

Security層 (OpenClaw Enterprise)

- `aws_guardduty_detector` — 全アカウントの脅威検知を管理アカウントに集約
- `aws_securityhub_hub` — CIS AWS Foundations Benchmark自動監査
- `aws_config_rule` — リソース設定変更を常時記録・ルール違反を検知
- `aws_cloudtrail` — 全APIコールをS3に記録・改ざん防止
- `aws_lambda_function` "openclaw_enterprise" — GuardDuty/Security Hub検知 → 自動対応
 - 高リスク: IAMポリシーを即時剥奪 + Slackアラート
 - 中リスク: Security Groupを隔離 + チケット自動生成
 - 低リスク: ログ記録 + 週次レポートに集約

Compliance層

- `aws_config_conformance_pack` — CIS Level 1/2を自動適用
- `aws_cloudwatch_metric_alarm` — Rootアカウント使用・MFAなしIAMユーザーを検知
- AWS Organizations SCP — 危険なアクション (S3パブリック公開・リージョン外リソース作成) を組織全体で禁止

OpenClaw Enterprise フロー

GuardDuty / Security Hub 検知

EventBridge Rule (重要度でフィルタ)

|

Lambda: openclaw_enterprise

|

└─ [CRITICAL] IAMロール権限を即時剥奪 → Slackに緊急通知

└─ [HIGH] Security Groupでネットワーク隔離 → Jiraチケット自動作成

└─ [MEDIUM] CloudWatch Logsに記録 → 週次セキュリティレポートに集約

Type-Omega: Cloud-Native Edition 詳細設計

ネットワーク構成

Internet

|

AWS Verified Access (VPNなし・IDベースZTNA)

|

└─ 認証: IAM Identity Center + デバイス証明書

|

Private Subnet (IGWなし)

|

└─ 社内アプリ (Lambda / ECS Fargate)

└─ 社内RAGシステム (Bedrock Knowledge Base)

└─ 開発者セルフサービスポータル (Lambda + API Gateway)

|

VPC Endpoints (全AWSサービスをPrivateLinkで接続)

主要コンポーネント

Identity層

- aws_iam_identity_center — クラウドネイティブSSO
- SCIM自動プロビジョニング (Okta / Google Workspace連携)
- aws_verified_access_instance — VPN不要のZTNA。IDとデバイス証明書でアクセス制御
- 全アクセスにMFA強制・セッションタイムアウト15分

Network層

- IGWなし — インターネットへの直接経路を持たない閉域設計
- VPC Endpoints — S3・Bedrock・DynamoDB・CloudWatch Logs・SSMをすべてPrivateLinkで接続
- aws_networkfirewall_firewall — 許可された宛先以外への通信を全遮断

Application層 (社内RAGシステム)

- `aws_bedrockagent_knowledge_base` — 社内ドキュメント（Confluence / S3）をベクトル化
- Claude 3 Sonnet — 自然言語で社内ドキュメントを検索・要約
- `aws_lambda_function` "rag_query" — Slack Bot / Webポータルからの質問を処理
- `aws_dynamodb_table` "conversation_history" — 会話履歴の保持

Developer Self-Service層

- `aws_lambda_function` "provisioner" — 開発者がAPIで環境をリクエスト
- AWS Service Catalog — 承認済みリソーステンプレートのカタログ
- SCPで上限を設定 — 開発者は自由だがGuardrailsの外には出られない
- GitHub Actions + OIDC — VPC外からのCI/CDをシークレットレスで実行

Security層

- `aws_guardduty_detector` — 異常検知
- `aws_lambda_function` "openclaw_cloud_native" — 自動対応
 - 異常なIAMアクティビティ → 即時セッション無効化
 - 未知のIPからのアクセス → Verified Accessポリシーで即時遮断
- AWS Organizations SCP — 全アカウントへのポリシー強制
 - リージョン制限（ap-northeast-1のみ許可）
 - S3パブリックアクセス禁止
 - 暗号化されていないEBSボリューム作成禁止

CI/CD パイプライン（Type-Omega専用）

```

GitHub Push
|
GitHub Actions (OIDC認証 → AWSにシークレットレスでアクセス)
|
├─ terraform plan (PRでコメント自動投稿)
├─ terraform apply (mainブランチマージ時のみ)
└─ Lambda zip自動ビルド・デプロイ
  
```

セキュリティ設計の対比

観点	Type-B	Type-Omega
脅威への対応	検知してから対応（事後対応）	そもそも侵入させない（事前防御）
アクセス制御	ネットワーク境界（VPN内＝信頼）	ID・デバイス証明書（場所に関係なく検証）

観点	Type-B	Type-Omega
コンプライアンス	CIS Benchmark自動監査・レポート	SCPによるポリシー強制（違反自体を不可能に）
変更管理	承認フロー必須・変更記録を全保持	Infrastructure as Code・GitOpsで自動追跡
インシデント対応	重要度別に人間へエスカレーション	自動遮断・自動復旧（人手介入を最小化）

共通セキュリティ基盤（両アーキテクチャ共通）

機能	設定
KMS	カスタマーマネージドキー・自動ローテーション・削除猶予30日
CloudTrail	マルチリージョン・ログファイル整合性検証・365日保持
GuardDuty	S3・EKS・RDS・Lambda保護を有効化
AWS Config	全リソースの設定変更を記録・2555日保持
VPC Flow Logs	全トラフィックを90日保持・KMS暗号化
Macie	S3内の個人情報・機密情報を自動検出
Access Analyzer	外部公開リソースを継続的にスキャン

ファイル構成（実装予定）

```
internal-infra/
├─ terraform/
│   └─ type-b/
│       ├── main.tf           # Type-B: Enterprise Edition
│       └─ type-omega/
│           └─ main.tf        # Type-Omega: Cloud-Native Edition
├─ lambda/
│   ├── openclaw_enterprise/ # Type-B: OpenClaw Enterprise
│   │   ├── main.py
│   │   ├── test_main.py
│   │   └─ requirements.txt
│   └─ openclaw_cloud_native/ # Type-Omega: 自動対応Lambda
│       ├── main.py
│       ├── test_main.py
│       └─ requirements.txt
```

```
|   └─ rag_query/                # Type-Omega: RAGクエリLambda
|       └─ index.js
|       └─ index.test.js
|       └─ package.json
└─ Makefile
└─ README.md
```

設計思想

本プロジェクトはホテル予約システムと同じコアメッセージを社内インフラに適用しています。

Type-Bが選ぶのは「変えないことで守る安心」。既存の組織文化と資産を尊重し、社員が気づかないところだけをAIで強化する。

Type-Omegaが選ぶのは「IDだけを信頼する自由」。場所・デバイス・ネットワークへの依存をゼロにし、どこからでも安全に働ける環境を実現する。

どちらが優れているかという問いは成立しない。**どんな組織文化を支えたいか**という問いへの答えが、インフラの思想を決定する。